

Project Methodology: Building an Enterprise AI Policy

Author: Kyle Joseph Picard **Project Focus:** GRC, Framework Mapping, Policy Development

1. Why I Built This

Generative AI is moving fast. Because of this, "Shadow AI" has become a massive blind spot for organizations. Employees are quietly putting company data into public chatbots, and I wanted to tackle this problem head on.

I wrote this Enterprise AI Acceptable Use Policy as a portfolio project. It gave me a chance to practice taking a modern, unstructured technical risk and governing it using formal administrative controls. My goal was not to write a document that simply says "no." Instead, I wanted to show how a business can safely leverage these tools without failing a compliance audit.

2. How I Applied the Frameworks

To make sure this policy was grounded in reality, I mapped my core sections to three major regulatory and security frameworks. Here is a breakdown of my exact thought process.

A. HIPAA (Health Insurance Portability and Accountability Act)

- **Where I applied it:** Section 5 (Data Classification and AI Usage Rules).
- **My Thought Process:** In my day job, I manage hundreds of highly sensitive client records. That experience makes HIPAA compliance my absolute baseline for data privacy. The HIPAA Security Rule requires strict safeguards against unauthorized disclosures. To meet that standard, I explicitly defined ePHI and client records as restricted data. If an employee pastes medical data into a public model, it is now a clear and documented violation of corporate policy. This directly protects the organization from regulatory fines.

B. NIST AI RMF (Artificial Intelligence Risk Management Framework)

- **Where I applied it:** Section 4 (AI Tool Classification) and Section 6 (Employee Responsibilities).
- **My Thought Process:** I needed a standardized way to evaluate AI tools. The NIST AI RMF was the perfect fit. I focused specifically on its "Govern" and "Manage" core functions.
 - To satisfy the Govern principle, I categorized AI tools into two distinct groups. "Approved Enterprise" covers tools where data is siloed. "Prohibited Public" covers tools that use inputs for external training.
 - Next, I tackled the Manage principle by writing the "Output Verification" rule. LLMs are notoriously prone to hallucinations. Mandating a human fact-check before production use directly aligns with NIST guidelines for trustworthy AI.

C. NIST SP 800-53 (Security and Privacy Controls)

- **Where I applied it:** The overall document structure and Section 7 (Incident Reporting).
- **My Thought Process:** I wanted this document to hold up in a real corporate audit. NIST SP 800-53 requires organizations to maintain formal policies for system usage and incident response. I satisfied these federal requirements in two specific ways. First, I defined exactly who can use what data to establish foundational Access Control. Second, I created a mandatory reporting pathway in Section 7 to handle Incident Response in the event of data spillage.

3. Takeaways

This project was a great exercise in translating abstract technical risks into actionable business rules. I spent quite a bit of time studying real corporate policies to nail down the dry, rigid tone these documents require.

Ultimately, the project reinforced a core GRC concept for me. We do not need to invent entirely new rulebooks for emerging technology. We can successfully govern new tools by adapting the established risk management frameworks we already trust.